

BLE 核销交互技术说明

正常核销与体验核销 · 小程序 / CloudBase / PostgreSQL / BLE 设备

当前实现版本	小程序 0.2.43 目标基线 · faceRecognition v103 · 数据库迁移 066
最终业务时点	人脸验证只建立 90 秒设备资格；只有设备回报 ok=true 且 status=2，服务端才原子扣次并生成工单。

- 90 秒内，二维码窗口可以关闭、重新打开和重新扫码；关闭窗口不取消资格，也不扣次。
- 服务器正式签发一次性设备授权后，设备只有 30 秒可接受该授权；30 秒不是设备服务时长。
- 核销成功后二维码永久关闭，页面立即跳转到同一核销工单；不能再次开机或再次扣次。
- 设备类型不使用 model 字段；当前按项目名称转换为全小写、无空格的拼音，例如“海洋之蕴” → haiyangzhiyun。
- 进入 status=2 后，设备内部不再区分项目；本次只接收 usage_count。每次对应多少分钟必须与米总确认，APP 和服务端不得硬编码。

文档用途：研发联调、设备固件验收、上线部署与现场故障排查。文档不包含 AppSecret、BLE 签名密钥、真实随机数、客户资料或生产令牌。

1. 交互主链路与不可突破的扣次门禁

1	2	3	4
选择业务 门店 / 客户 / 项目 / 次数	1:1 人脸 仅验证所选客户	90 秒资格 尚未扣次、可重开扫码	扫码 + BLE 识别本次目标设备
5	6	7	8
get_info 核对编号、类型、状态、nonce	30 秒 auth 服务端 HMAC 一次性授权	设备 status=2 ok=true 且回执一致	原子核销 扣所选次数、生成原工单

服务端必须同时满足：资格属于当前登录身份和当前业务参数、资格未过 90 秒、设备已登记、二维码校验通过、设备 status=1、nonce 未用、授权未过 30 秒、回执对应原授权且 status=2。任意一项失败都不得调用原有核销事务。

防重复设计

- 资格一旦签发授权即锁定原设备，不能换设备重复开机。
- 同一个 authorization / device_id + nonce 只允许完成一次；重试返回原工单，不再次扣次。
- 客户端本地保存不含客户明文的办理进度；若 BLE 在 auth 后断开，先 query_status / 恢复服务端原结果，禁止盲目重签。

当前状态机

状态	含义	页面行为	是否扣次
FACE_PENDING	尚未通过人脸	只允许拍照验证	否
QUALIFIED	90 秒资格有效	允许打开 / 关闭 / 重开二维码	否
AUTH_ISSUED	30 秒一次性授权已签发	只核对原设备，不得换设备重签	否
DEVICE_WORKING	设备回报 ok=true,status=2	立即提交服务端确认	服务端确认后
FINALIZED	核销事务已完成	二维码永久关闭并跳转工单	已扣一次
EXPIRED / FAILED	资格或授权失效 / 校验失败	明确提示且重新从安全节点办理	否

2. 二维码窗口、设备识别与 BLE 行协议

二维码窗口规则

- 人脸通过即由服务端建立 90 秒资格；倒计时来自服务端 expiresAt，不能只相信手机本地时间。
- 90 秒内用户可主动关闭窗口，再次点击“开启蓝牙并扫码”继续；关闭、取消扫码、未找到设备、连接失败都不扣次。
- 资格过期后按钮失效，并提示重新做人脸验证；不得沿用旧二维码、旧 nonce 或旧授权。
- 一旦服务端返回核销工单，当前资格标记 FINALIZED，二维码入口永久关闭并导航到工单详情。

二维码与设备发现

项目	实现规则
二维码	支持 nc://bind?sn=NCM...&code;=六位数字；兼容 & 与纯文本 SN + code。二维码只识别本次设备，不建立永久绑定。
广播名	NCM-{SN 最后 6 位}，仅用于发现；连接后仍以 get_info 返回身份为准。
通信通道	运行时发现唯一同时具备 write 与 notify/indicate 的主服务；零个或多个候选均拒绝授权，避免写错通道。
帧格式	UTF-8 JSON，每条消息以换行符 \n (0x0A) 结束；支持分片拼接。

设备类型

expected_device_type	由当前项目名称转为拼音全小写并移除所有空格和标点。示例：露思康辰 → lusikangchen。APP 不发送 model，也不以 WD-BLE 作为当前业务固定值。
----------------------	---

关键消息示例（均为假数据）

```
{ "ver": "1.0", "seq": 1, "cmd": "get_info", "ts": 1770000000 }
{ "cmd": "info", "device_id": "NCM00000000001", "device_type": "mofajingfu", "status": 1, "nonce": "001122...eeff" }
{ "ver": "1.0", "seq": 2, "cmd": "auth", "auth": { "command": "enter_work", "device_id": "NCM00000000001", "device_type": "mofajingfu", "nonce": "001122...eeff", "usage_count": 3, "issued_at": 1770000000, "expire_at": 1770000030, "signature": "<hex>" } }
{ "cmd": "auth_result", "ok": true, "device_id": "NCM00000000001", "nonce": "001122...eeff", "status": 2 }
```

签名规范

当前服务端采用 HMAC-SHA256。BLE_AUTH_SIGNING_KEY 只能在 CloudBase 环境变量中配置，禁止写入小程序、仓库、聊天或 PDF。签名覆盖 command、device_id、device_type、usage_count、expire_at、issued_at、nonce 的统一规范串；设备端必须使用完全相同的字段顺序与编码。

3. CloudBase、数据库与账务安全

阶段	服务端动作	数据库约束 / 安全结果
建立资格	复用既有客户人脸 1:1 结果和业务参数，生成 90 秒短期资格	不建立核销单、不扣客户余额 / 老师额度
登记设备	按 SN/device_id、二维码校验哈希、设备类型查有效设备	未知、封存、类型不符设备拒绝
签发授权	保存 nonce、usage_count、设备、30 秒过期时间与 HMAC	唯一约束阻止 nonce 重放；资格锁定设备
确认工作	只接受 status=2 且与原授权一致的回执	同一授权只能 finalized 一次
核销写入	调用既有正常核销 / 体验核销原子事务	继续执行余额、额度、角色、门店、次数与幂等校验
恢复	重复 work-report 或客户端重试读取原结果	返回原工单，不重复扣次

失败绝不扣次

- 二维码错误、相机权限、蓝牙关闭、设备未找到、连接失败、通信通道异常、get_info 超时、设备编号/类型/状态/nonce 不符、签名错误、授权过期、设备拒绝、网络失败，均不得触发核销事务。
- 如果设备是否已经进入 status=2 不确定，页面必须显示“请勿重复办理”，先恢复原授权 / 查询原设备 / 检查原工单，而不是重新签发。

部署顺序

顺序	操作	验收
1	先执行 065，再执行 066-01-ble-verification-authorization.sql	事务成功且无错误
2	在 CloudBase 私密配置 BLE_AUTH_SIGNING_KEY	不出现在日志、聊天、仓库
3	上传 faceRecognition-v103.zip 并安装依赖	health 返回 version=v103
4	执行 066-readonly-verify.sql	10 项只读检查均符合 README 预期
5	重新上传小程序开发版并设为体验版	真机按验收矩阵逐项测试

未执行 066 或未上传 v103 时，小程序必须明确提示“BLE 数据表尚未部署”或“签名密钥配置错误”，不能悄悄回退到人脸后直接核销。

4. 小程序错误反馈矩阵（用户可处理）

每个错误反馈均由标题、原因、下一步、错误代码组成。可安全重试仅表示“在 90 秒资格有效且未签发不可逆授权时可重试”，不代表允许绕过校验。

代码 / 场景	给用户看的提示	处理与扣次
BLE_QR_CANCELLED / WINDOW_CLOSED	扫码已关闭；90 秒内可重新打开	可重试；不扣次
BLE_QR_INVALID	不是设备机身 nc://bind 二维码	换正确二维码；不扣次
BLE_QR_SCAN_FAILED	无法使用相机扫码	开启微信相机权限；不扣次
BLE_API_UNAVAILABLE	微信版本不支持所需 BLE 能力	升级微信 / 系统；不扣次
BLE_SWITCH_OFF	手机蓝牙未开启	开启系统蓝牙及权限；不扣次
BLE_ADAPTER_*	蓝牙初始化或权限失败	重启微信 / 手机并检查权限；不扣次
BLE_DEVICE_NOT_FOUND	15 秒内未找到目标设备	靠近、通电、断开其他手机；不扣次
BLE_CONNECTION_FAILED / CLOSED	连接失败或中断	授权前可重试；授权后先恢复状态；不扣次直到确认
BLE_INFO_TIMEOUT	读取设备信息超时	确认设备待机并靠近；不扣次
BLE_WRITE_FAILED	指令发送失败	保持靠近；未确认 status=2 不扣次
BLE_DEVICE_ID_EMPTY	微信未返回蓝牙标识	重新扫码；不扣次
BLE_DEVICE_NOT_READY	设备未处于待授权状态	在设备端结束旧服务后重试；不扣次
BLE_DEVICE_NOT_WORKING	设备尚未明确进入工作状态	继续等待 / 核对；服务端不扣次
BLE_QUALIFICATION_EXPIRED	90 秒资格已过期	重新人脸验证；不扣次

统一未知错误	显示原错误代码和发生时间，提醒用户不要盲目重复扫码；先检查设备是否已经启动及是否已有工单。
--------	---

5. 小程序错误反馈矩阵（需管理员 / 设备技术处理）

代码 / 场景	阻断原因	安全处置
PROTOCOL_CHANNEL_MISSING	没有同时支持写入与通知的服务	升级固件；不授权
PROTOCOL_CHANNEL_AMBIGUOUS	存在多个候选通信通道	拒绝猜测，固件明确唯一通道
DEVICE_ID / NAME_MISMATCH	二维码、广播名或固件身份不一致	停用设备并核查标签 / 写号
DEVICE_TYPE_MISMATCH	项目拼音类型与设备实际类型不一致	改扫对应类型设备；不授权
NONCE_INVALID / REUSED	nonce 格式错误或已经使用	禁止重放；先核对原工单
DEVICE_BUSY_OTHER_SESSION	设备 status=2 且不属于当前授权	禁止接管和重复扣次
DEVICE_NOT_PROVISIONED	设备未完成总部登记 / 产线初始化	完成设备登记后再办理
PROGRESS_SAVE_FAILED	客户端无法保存防重复进度	禁止继续授权，先清理存储
AUTHORIZATION_ALREADY_ISSUED	同一资格已签发授权	只连接原设备核对，不重复签发
AUTHORIZATION_DEVICE_LOCKED	资格已锁定另一设备	禁止换设备，等待资格结束或恢复原设备
AUTHORIZATION_EXPIRED	30 秒授权未及时被设备接受	核对设备未启动后重新人脸
DEVICE_RECEIPT_MISMATCH	status=2 回执与原授权不一致	禁止生成工单，人工核查
ALREADY_FINALIZED	原核销工单已生成	直接打开原工单；永久关闭二维码
BLE_SCHEMA_MISSING	迁移 066 未部署	执行 SQL 与只读验收
BLE_SIGNING_KEY_INVALID	云函数签名密钥缺失 / 过短	私密配置环境变量；禁止聊天传密钥
FORBIDDEN / SESSION_EXPIRED	账号无权或登录已失效	重新登录或由管理员分配权限

6. 设备 V2.0 错误码与断线恢复

设备码	含义	APP 行为
400 / 403 / 404	请求格式错误 / 拒绝授权 / 未知命令	显示固件协议问题，不扣次
1001	签名无效	停止授权，核对双方算法与密钥
1002	授权已过期	不得重复发送原 auth；核对设备状态
1003 / 1004	nonce 不匹配 / 已使用	重新 get_info 或恢复原工单，禁止重放
1005	device busy	若属于本次授权则 query_status；否则禁止接管
1006 / 1007	device_id / device_type 不匹配	停止使用错误设备
1008 / 1009	不支持 enter_work / 未出厂登记	升级固件或完成产线登记
1011	usage_count 非法	保留用户所选次数，不得偷偷改成固定 1 次

auth 后断线的处理顺序

- 客户端保留 authorizationToken、device_id、nonce 与已收到的设备结果，不保存签名密钥。
- 重新连接原设备，发送 query_status。若 status=2 且 nonce 对应原授权，补报服务端 confirm；服务端以原记录中的 usage_count 为准。
- 如果 status 仍不是 2，服务端不扣次。只有确认授权未生效且资格规则允许时，才能从安全节点重新办理。
- 网络重试、页面重进、重复 work-report 都必须返回原工单，不能产生第二笔扣次。

关键提醒

如果设备可能已启动但手机未收到结果，页面不得直接显示普通“失败后重试”。必须显示“状态待确认，请勿重复办理”，优先恢复原设备和原工单。

7. 设备职责、残余风险与真机验收

设备固件职责（小程序不能代替）

- 设备在 status=2 使用过程中异常断电，必须把 active_session、usage_count、剩余服务额度、会话标识和恢复所需状态写入非易失存储；重新上电直接恢复原会话，不重新授权、不再次核销。
- 客户提前完成时，允许在设备本机主动退出并回到 status=1。主动退出与异常断电恢复必须区分；APP 不发送 control 指令。
- usage_count 对应的服务分钟数由设备统一配置，待与米总确认。APP / 服务端始终只发送次数，不发送分钟数。
- status=2 后不再区分项目，可在设备本机自由选择或切换项目，共用本次次数对应的服务额度。

当前 V2.0 残余风险

未签名工作回执	当前设备返回 auth_result/status 时没有独立设备签名。服务端能校验原授权、nonce、设备登记、状态和幂等，但无法密码学证明 status=2 回执一定由真实设备生成。上线前至少需要确认 BLE 链路和固件不可被普通客户端伪造；后续建议升级为设备私钥签名回执或挑战响应。
---------	--

真机验收清单

场景	预期结果
90 秒内关闭再打开二维码	继续原资格；不扣次
第 91 秒再打开	资格过期；重新人脸；不扣次
错误二维码 / 设备编号 / 设备类型	明确错误并阻断授权
手机蓝牙关闭 / 权限拒绝 / 未找到设备	给出可执行指引；不扣次
auth 签发后超过 30 秒	设备和服务端均拒绝；不扣次
设备返回 ok=true,status=2	只扣用户所选次数；二维码永久关闭；跳同一工单
设备返回 status≠2 或错误码	不扣次；显示对应设备错误
auth 后断网 / 断蓝牙	恢复原设备状态与原工单；不重复授权 / 扣次
重复点击 / 重复回报 / 页面重进	幂等返回原工单
正常核销与体验核销	均可选择 1—999 次；分别扣客户余额 / 老师体验额度
设备工作中异常断电	固件恢复剩余额度和原会话；后台不重复核销
设备本机主动退出	结束会话回到 status=1；旧 auth 不可恢复

结论：90 秒是人脸后的扫码资格窗口；30 秒是一次性设备授权接受窗口；真正的账务提交点只有一个——设备明确进入工作状态 2，并且服务端复核全部资格后调用原有原子核销事务。